

DOCUMENTACIÓN TÉCNICA DE LABORATORIO: ATAQUES DE RED L2 Y L3

Instituto Tecnológico de Las Américas (ITLA)

Materia: Seguridad de Redes

Profesor: Jonathan Rondón

Estudiante: Anthony De Los Santos

Matrícula: 2025-1335

Entorno de Laboratorio: PNETLab

1. OBJETIVO DEL LABORATORIO

Demostrar de forma práctica la explotación y mitigación de vulnerabilidades en protocolos de Capa 2 (VTP, DTP) y Capa 3 (ARP, DNS) dentro de un entorno virtualizado. El laboratorio busca evidenciar el impacto de configuraciones por defecto en switches y la falta de validación de identidad en redes locales, logrando:

- La inyección y eliminación de VLANs mediante ataques VTP.
- La evasión de segmentación mediante DTP VLAN Hopping (conversión de interfaz de acceso a troncal).
- La redirección de tráfico mediante DNS Spoofing apoyado en ARP Poisoning hacia el dominio itla.edu.do.

2. DOCUMENTACIÓN DE LA RED

El entorno virtualizado se compone de una arquitectura jerárquica con equipos Cisco y nodos Linux/Windows distribuidos de la siguiente manera:

VLAN 35 - Red Administrativa (Gestión)

- Descripción: Segmento aislado destinado exclusivamente al tráfico de administración de la infraestructura.
- ID de Subred: 10.25.35.0/24
- Gateway (R1-Core subinterfaz .35): 10.25.35.1
- Switch-Core (SVI Gestión): 10.25.35.2
- Switch-2 (SVI Gestión): 10.25.35.3
- PC de Administración: 10.25.35.10 (Asignación Estática)

VLAN 133 - Red de Usuarios (Entorno de Pruebas)

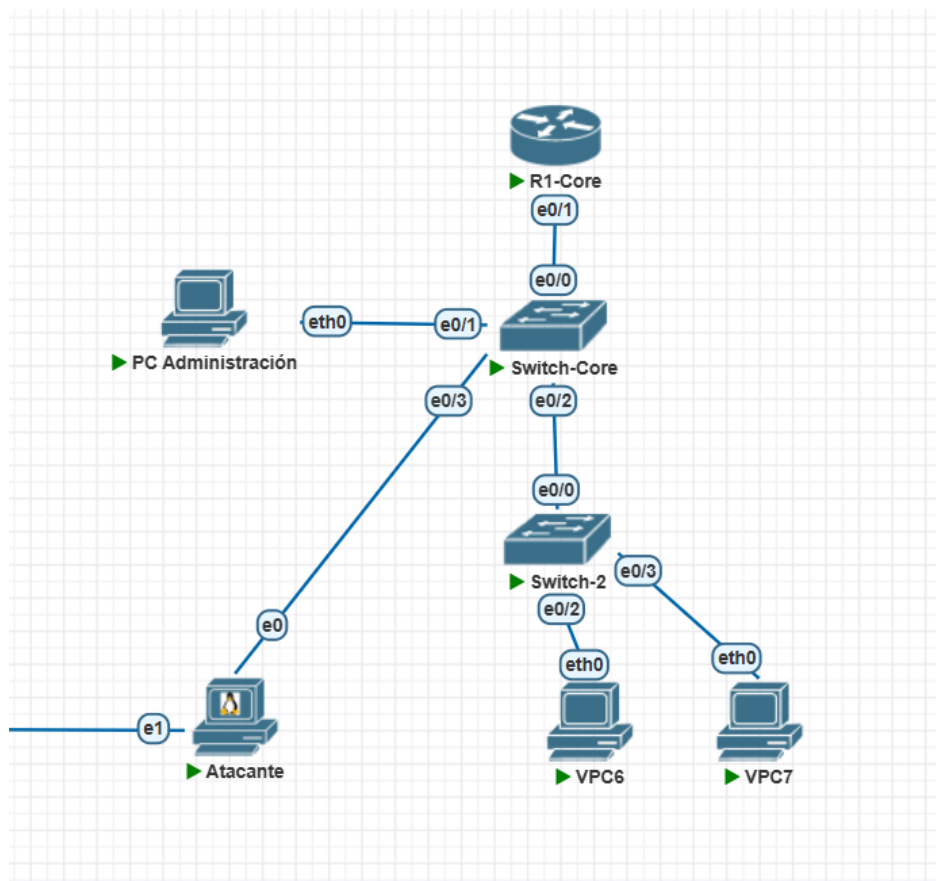
- Descripción: Segmento de acceso general donde conviven los usuarios legítimos, la máquina víctima y el equipo del atacante.
- ID de Subred: 10.25.133.0/24
- Gateway (R1-Core subinterfaz .133): 10.25.133.1
- Máquina Atacante (Linux): 10.25.133.12 (Interfaz e0 / ens3)
- Máquinas Víctima (Windows 10 / VPCs): Asignación dinámica vía DHCP.

Red Perimetral (WAN / ISP)

- Descripción: Enlace hacia el exterior que provee salida a Internet.
- Interfaz de Salida (Atacante - e1): Asignación dinámica provista por el router doméstico.

VLAN 999 - Nativa (Blackhole)

- Descripción: VLAN aislada sin direccionamiento IP asignado. Configurada como VLAN nativa en todos los enlaces troncales (802.1Q) para mitigar vectores de ataque de doble etiquetado.



3. ATAQUE 1: VLAN TRUNKING PROTOCOL (VTP)

Herramienta Utilizada: Yersinia (Interfaz Gráfica)

3.1 Objetivo del Ataque

Injectar paquetes VTP manipulados en la red con un número de revisión superior al actual del dominio VTP (LAB_SEGURIDAD). El objetivo es forzar a los switches de la infraestructura a actualizar su base de datos de VLANs, permitiendo agregar nuevas VLANs (ej. VLAN 123 "cumplido") o borrar las existentes, provocando una denegación de servicio (DoS) a nivel de capa 2.

3.2 Requisitos

- Sistema operativo Linux (ej. Pop!_OS / Ubuntu) con entorno gráfico.
- Herramienta yersinia instalada (sudo apt install yersinia).
- Conexión física/lógica a un puerto del switch.
- Dominio VTP de la red objetivo sin contraseña (o contraseña comprometida).

3.3 Documentación del Funcionamiento

1. Se ejecuta Yersinia en modo gráfico mediante el comando yersinia -G con privilegios de superusuario.
2. Se selecciona la interfaz de red conectada al switch (ej. ens3).
3. En la pestaña VTP, se identifica el dominio VTP activo capturado en el tráfico (en este caso, LAB_SEGURIDAD).
4. Se ejecuta el ataque "Adding one VLAN", definiendo el VLAN ID (ej. 123) y el VLAN Name (cumplido).
5. Yersinia falsifica un paquete Summary Advertisement y un Subset Advertisement incrementando exponencialmente el número de revisión. Al recibirlo, los switches clientes sobrescriben su base de datos vlan.dat.
6. Para el borrado, se inyecta un Subset Advertisement con la lista de VLANs vacía, eliminando la conectividad de los usuarios.

VTP attack parameters (as superuser)

adding one vlan

VLAN ID: 123

VLAN Name: cumplido

Cancel OK

Protocol	Code	Domain	MD5	Interface	Count	Last seen
CDP	0					
DHCP	0					
802.1Q	0					
802.1X	0					
DTP	0					
HSRP	0					
ISL	0					
MPLS	0					
STP	0					
VTP	0					

Field Value

Source MAC AA:BB:CC

Destination MAC 01:00:0C

Version 01

Code 01

Domain LAB_SEG

MD5 7FE984D

Updater 10.13.58

Revision 00000000

15:54:44

Mode stats cleared

Code	Domain	MD5	Interface	Count	Last seen
02 SUBSET	LAB_SEGURIDAD		ens3	2	11 Jun 16:14:18
03 REQUEST	LAB_SEGURIDAD		ens3	4	11 Jun 16:14:17
01 SUMMARY	LAB_SEGURIDAD	7FE984DA4F4298A8	ens3	1	11 Jun 16:14:18
02 SUBSET	LAB_SEGURIDAD		ens3	1	11 Jun 16:14:18
01 SUMMARY	LAB_SEGURIDAD	0C4D8DE4E6D2B85B	ens3	2	11 Jun 16:09:12
02 SUBSET	LAB_SEGURIDAD		ens3	2	11 Jun 16:09:12
01 SUMMARY	LAB_SEGURIDAD	0C4D8DE4E6D2B85B	ens3	2	11 Jun 16:14:18
02 SUBSET	LAB_SEGURIDAD		ens3	2	11 Jun 16:14:18
01 SUMMARY	LAB_SEGURIDAD	0C4D8DE4E6D2B85B	ens3	1	11 Jun 16:14:17
01 SUMMARY	LAB_SEGURIDAD	7FE984DA4F4298A8	ens3	2	11 Jun 16:14:18

VLAN Trunking Protocol

Source MAC 02:C2:DC:7F:8E:F3 Destination MAC 01:00:0C:CC:CC:CC

Version 01 Code 03 Domain LAB_SEGURIDAD

MD5 00000000000000000000000000000000 Updater 10.13.58.1

Revision 5555 Timestamp Start value 1

Followers 1 Sequence 1

0x0000: 0100 0ccc cccc aabb cc00 0230 0055 aaaa0.U..
 0x0010: 0300 000c 2003 0101 010d 4c41 425f 5345LAB_SE
 0x0020: 4755 5249 4441 4400 0000 0000 0000 0000 GURIDAD.....

```
Switch-Core#sh vlan brief
```

VLAN	Name	Status	Ports
1	default	active	Et1/0, Et1/1, Et1/2, Et1/3
35	Admin_VLAN	active	Et0/1
123	cumplido	active	
133	Users_VLAN	active	
999	Native_Blackhole	active	
1002	fddi-default	act/unsup	
1003	token-ring-default	act/unsup	
1004	fddinet-default	act/unsup	
1005	trnet-default	act/unsup	

3.4 Contramedidas y Mitigación (VTP)

Para evitar la alteración no autorizada de la base de datos de VLANs:

- VTP Password: Configurar una contraseña robusta en el dominio VTP. Los paquetes sin el hash MD5 correcto serán descartados. (vtp password [clave]).
- VTP Transparent Mode: Si no es estrictamente necesario sincronizar VLANs dinámicamente, configurar los switches en modo transparente (vtp mode transparent) u off.
- VTP Version 3: Utilizar VTPv3, el cual soporta autenticación criptográfica mejorada y previene que switches no designados como "Primary Server" sobrescriban la base de datos.

4. ATAQUE 2: DTP VLAN HOPPING (Acceso a Troncal)

Herramienta Utilizada: Scapy (Python) - Script Personalizado dtp.py

4.1 Objetivo del Script

El objetivo de este script es explotar el Dynamic Trunking Protocol (DTP) enviando tramas falsificadas tipo "Desirable" (0x03). Esto engaña al puerto de acceso del switch (si está configurado en dynamic auto o dynamic desirable) para que negocie y levante un enlace troncal (Trunk 802.1Q). Al lograrlo, el atacante tiene acceso a todas las VLANs permitidas en ese troncal.

4.2 Parámetros Usados

- Interfaz (iface): Interfaz de red del atacante (ej. eth0 o ens3).
- Dominio DTP/VTP (domain): lab.local / LAB_SEGURIDAD (Extraído del tráfico).
- Status DTP: 0x03 (Desirable/Desirable).
- Tipo de Encapsulación: 0xa5 (802.1Q).

4.3 Requisitos

- Intérprete de Python 3.
- Librería Scapy (pip install scapy).
- Módulo extendido DTP de Scapy (scapy.contrib.dtp).
- Permisos de ejecución como root.

4.4 Documentación del Funcionamiento

7. El atacante ejecuta el script dtp.py seleccionando la opción [3] Solo DTP - Negociar trunk únicamente.
8. El script genera una trama Ethernet con destino a la dirección Multicast de Cisco (01:00:0c:cc:cc:cc).
9. Se encapsula el payload LLC/SNAP con el código de protocolo DTP (0x2004).
10. Se inyectan de manera continua durante 25-30 segundos paquetes DTP declarando un estado Desirable.

11. El puerto del switch cede a la negociación y transiciona su estado operativo de estático/acceso a Trunk, otorgando al atacante la capacidad de inyectar tráfico con etiquetas 802.1Q hacia otras redes (VLAN Hopping).

```
root@user-pc: /home/user X + v

dsap      = 0xaa
ssap      = 0xaa
ctrl      = 3
###[ SNAP ]###
OUI       = Cisco Systems, Inc (00:00:0c)
code      = 0x2004
###[ DTP ]###
ver       = 1
\tlvlist  \
|###[ DTP Domain ]###
|type     = 1
|length   = 17
|domain   = 'LAB_SEGURIDAD'
|###[ DTP Status ]###
|type     = 2
|length   = 5
|status   = '\x03'
|###[ DTP Type ]###
|type     = 3
|length   = 5
|dtptype  = '\xa5'
|###[ DTP Neighbor ]###
|type     = 4
|len      = 10
|neighbor = 50:af:32:00:0a:00

🔥 Sending DTP Desirable frames...
[[02s] Enviados 3 frames DTP | Negociando trunk...
```

```
Switch-Core#sh int trunk
```

Port	Mode	Encapsulation	Status	Native vlan
Et0/0	on	802.1q	trunking	999
Et0/2	on	802.1q	trunking	999
Et0/3	auto	n-802.1q	trunking	1

4.5 Contramedidas y Mitigación (DTP)

Para prevenir negociaciones no deseadas de enlaces troncales:

- Deshabilitar DTP: Ejecutar el comando `switchport nonegotiate` en todos los puertos (tanto de acceso como troncales). Esto apaga el envío y procesamiento de tramas DTP.
- Forzar el modo de acceso: Asegurar explícitamente que los puertos orientados a usuarios finales estén en modo acceso con el comando `switchport mode access`.
- VLAN Nativa Blackhole: Como está documentado en la red (VLAN 999), usar una VLAN nativa inactiva evita el Double Tagging.

5. ATAQUE 3: DNS SPOOFING / POISONING

Herramienta Utilizada: Scapy (Python) - Scripts ARP.txt y DNS_SPOOFING.txt

5.1 Objetivo del Script

Interceptar las solicitudes de resolución de nombres (DNS) originadas por la máquina víctima dirigidas al dominio oficial `itla.edu.do`. El script responde de manera fraudulenta (Spoofing) inyectando la dirección IP local del atacante, redirigiendo así el tráfico web de la víctima hacia un servicio controlado por el auditor, previo establecimiento de un ataque de intermediario (Man-in-the-Middle) vía ARP Poisoning.

5.2 Parámetros Usados

- ATTACKER_IP: 10.25.133.12 (IP del servicio web falso).
- VICTIM_IP: IP dinámica de la máquina víctima en la VLAN 133.
- GATEWAY_IP: 10.25.133.1 (R1-Core).
- TARGET_DOMAIN: `itla.edu.do`.

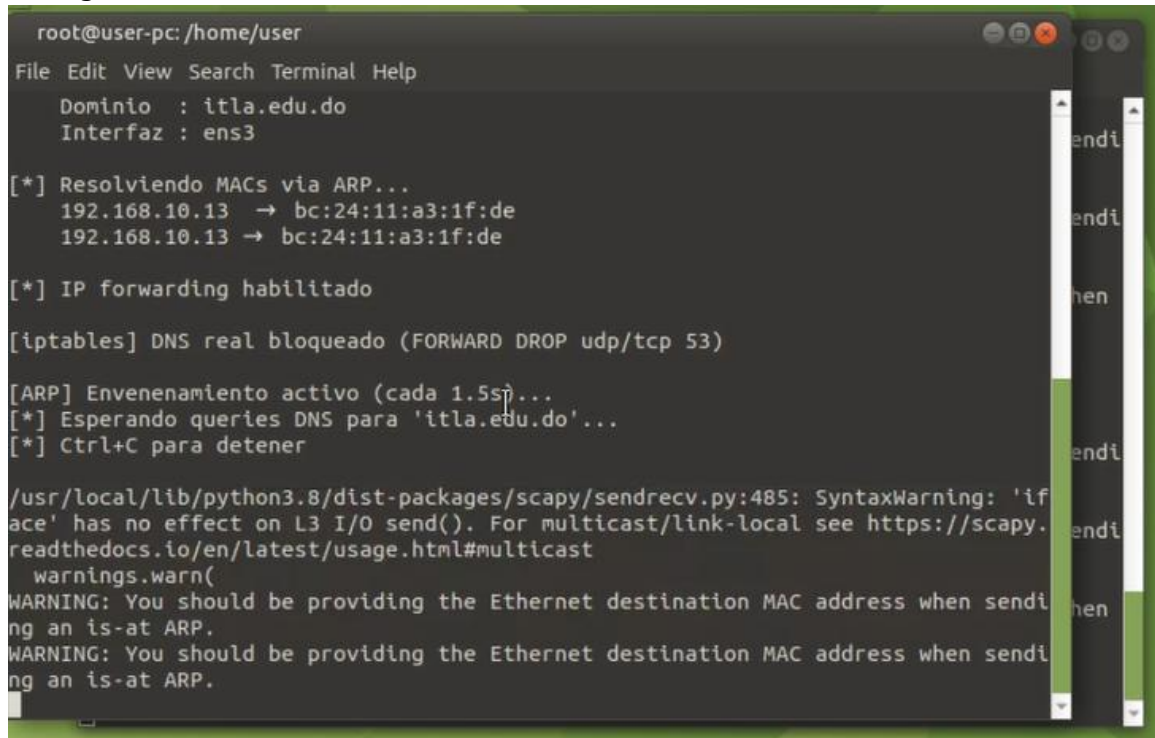
5.3 Requisitos

- Intérprete de Python 3 y Scapy.
- Ejecución encadenada: El envenenamiento ARP (ARP.txt) es un prerequisite obligatorio para situar al atacante en medio de las comunicaciones antes de ejecutar el DNS Spoofing.
- Activación de IP Forwarding en Linux (`sysctl -w net.ipv4.ip_forward=1`).
- Reglas de iptables para bloquear la resolución DNS legítima en modo forward.

5.4 Documentación del Funcionamiento

12. Fase 1 (ARP Poisoning): El script ARP.txt resuelve las direcciones MAC de la víctima y el Gateway. Envía respuestas ARP gratuitas continuas indicándole a la víctima que la MAC del Gateway es la del atacante, y viceversa.

13. Fase 2 (Filtro Iptables): El script de DNS bloquea el tráfico de reenvío en el puerto 53 UDP/TCP (iptables -A FORWARD -p udp --dport 53 -j DROP), asegurando que el servidor DNS real del ISP no pueda responder a la víctima antes que el atacante (ganando la "carrera").
14. Fase 3 (Sniffing e Inyección): El script captura el tráfico con Scapy (sniff(udp port 53)). Al detectar un DNS Query (qr=0) solicitando el registro "A" de itla.edu.do, fabrica al instante un paquete DNS Response (qr=1) autoritativo devolviendo la IP 10.25.133.12.
15. La víctima guarda en su caché temporal la resolución falsa y al acceder al navegador es redirigida al servicio web local del atacante.



```
root@user-pc: /home/user
File Edit View Search Terminal Help
Dominio : itla.edu.do
Interfaz : ens3

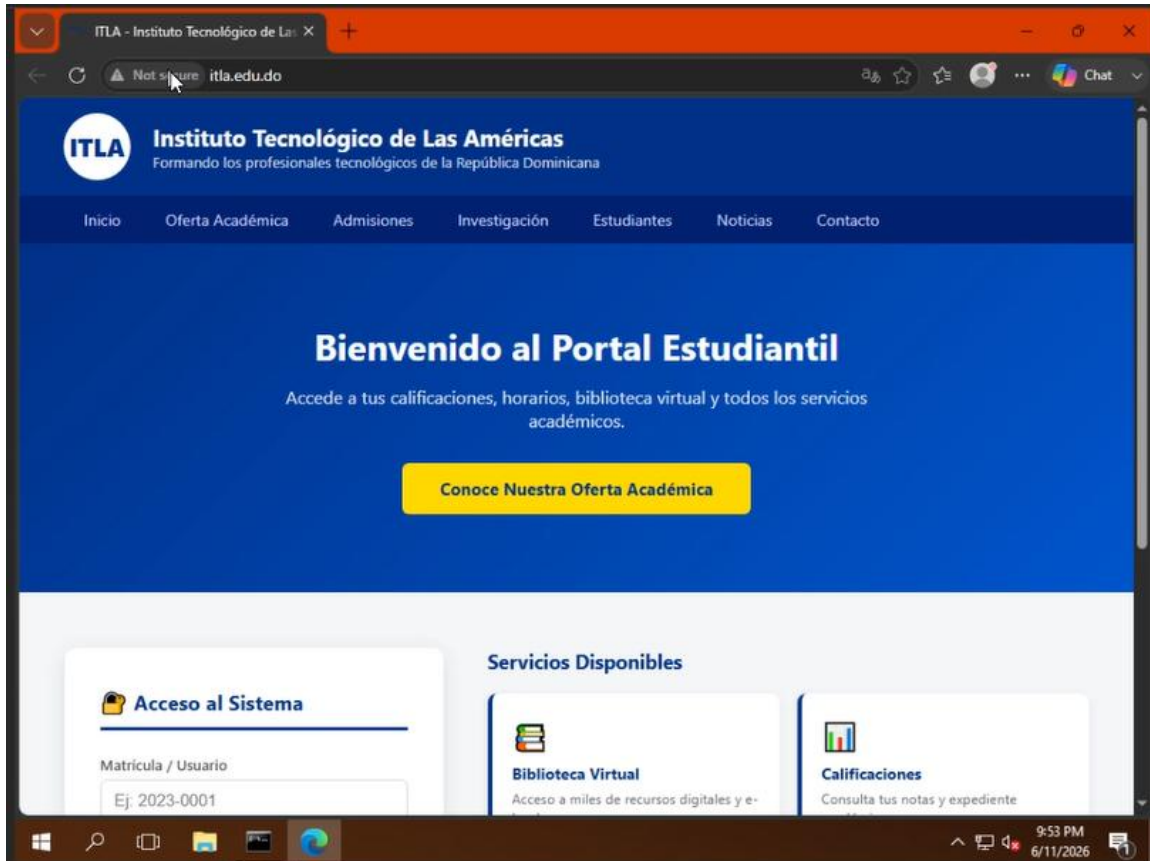
[*] Resolviendo MACs via ARP...
192.168.10.13  -> bc:24:11:a3:1f:de
192.168.10.13  -> bc:24:11:a3:1f:de

[*] IP forwarding habilitado

[iptables] DNS real bloqueado (FORWARD DROP udp/tcp 53)

[ARP] Envenenamiento activo (cada 1.5s)...
[*] Esperando queries DNS para 'itla.edu.do'...
[*] Ctrl+C para detener

/usr/local/lib/python3.8/dist-packages/scapy/sendrecv.py:485: SyntaxWarning: 'iface' has no effect on L3 I/O send(). For multicast/link-local see https://scapy.readthedocs.io/en/latest/usage.html#multicast
  warnings.warn(
WARNING: You should be providing the Ethernet destination MAC address when sending an is-at ARP.
WARNING: You should be providing the Ethernet destination MAC address when sending an is-at ARP.
```

5.5 Contramedidas y Mitigación (ARP & DNS)

Para proteger la capa de enlace y resolución de nombres contra el ataque Man-in-the-Middle:

- **Dynamic ARP Inspection (DAI):** Implementar DAI en el switch. Esta característica intercepta y valida las respuestas ARP contra la base de datos de DHCP Snooping binding. Las respuestas ARP que no coincidan con las MAC/IP legítimas asignadas son descartadas.
- **DHCP Snooping:** Prerrequisito para DAI; previene la asignación fraudulenta de IPs y crea la tabla de validación confiable.
- **Port Security:** Limita la cantidad de direcciones MAC permitidas por puerto, dificultando técnicas de inundación asociadas a la suplantación.
- **DNSSEC:** Implementar extensiones de seguridad para DNS, lo cual firma criptográficamente los registros DNS, permitiendo al cliente validar la autenticidad de la respuesta de itla.edu.do y rechazar inyecciones locales.